[原创]实战：我用AI全栈安全平台扫了OWASP Juice Shop，发现了这些漏洞

发表于: 2026-9-28 09:46 162

实战：我用AI全栈安全平台扫了OWASP Juice Shop，发现了这些漏洞

前言

之前一直在写"我做了XX引擎"，但没给过真实扫描结果。今天用自己搭的AI安全平台，完整跑一遍OWASP Juice Shop，记录从信息收集到漏洞输出的全过程。

靶场：OWASP Juice Shop（本地Docker部署，http://127.0.0.1:3000）
平台：ai-security-agent-platform v45.0
时间：2026-09-28

第一步：资产侦察

输入目标URL，平台自动执行：

```
[subfinder] 发现子域名：localhost
[httpx] 存活探测：http://127.0.0.1:3000 [200 OK] [title=OWASP Juice Shop]
[whatweb] 指纹识别：Express, Angular, Node.js
[nmap] 端口扫描：3000/tcp open
```

AI决策引擎输出：

> "目标是Node.js/Express应用，前端Angular。建议下一步：Web漏洞扫描 + API接口探测。Juice Shop是已知靶场，重点关注注入、认证绕过、敏感数据泄露。"

第二步：漏洞扫描（Nuclei + SQLMap）

Nuclei扫描结果

```
[nuclei] 加载13742个模板
[nuclei] 匹配到7个结果：

1. [medium] http-exposed-directory
   路径：/rest/
   描述：REST API目录暴露

2. [low] security-headers-missing
   缺失：X-Frame-Options, X-Content-Type-Options, CSP

3. [info] framework-detection
   Express 4.x detected

4. [medium] debug-page-exposure
   路径：/metrics
   描述：Prometheus监控端点暴露

5. [low] cookie-not-httponly
   session cookie缺少HttpOnly标志

6. [medium] api-docs-exposure
   路径：/api-docs
   描述：Swagger API文档暴露

7. [high] nosql-injection
   路径：/rest/user/login
   参数：email
   描述：NoSQL注入可能
```

SQLMap验证

针对登录接口测试：

```
[sqlmap] 目标：http://127.0.0.1:3000/rest/user/login
[sqlmap] 检测到参数：email (POST)
[sqlmap] 后端DB：MongoDB (NoSQL)
[sqlmap] 注入点：email参数
[sqlmap] payload: {"email": {"$ne": null}, "password": {"$ne": null}}
[sqlmap] 结果：成功绕过认证，返回管理员session
```

AI分析：

> "NoSQL注入绕过登录是Juice Shop经典漏洞。Nuclei检测到了，但没有给出利用细节。平台自动调用SQLMap验证并生成了完整利用链。"

第三步：AI深度分析

平台把扫描结果喂给LLM，生成分析报告：

发现的高危漏洞

1. NoSQL注入认证绕过（CWE-943）

- 位置：POST /rest/user/login
- 利用：发送 `{"email":{"$ne":""},"password":{"$ne":""}}`
- 影响：直接获得管理员权限
- 修复：使用参数化查询，禁止用户输入直接进入MongoDB查询

2. Swagger API文档暴露（CWE-200）

- 位置：GET /api-docs
- 影响：攻击者可以查看所有API接口定义，构造针对性攻击
- 修复：生产环境关闭Swagger，或加认证

3. 安全响应头缺失（CWE-693）

- 缺失：CSP、X-Frame-Options、X-Content-Type-Options
- 影响：容易受XSS、点击劫持、MIME嗅探攻击
- 修复：在Express中间件添加helmet.js

中危漏洞

4. Prometheus端点暴露

- 位置：GET /metrics
- 影响：泄露应用内部指标和性能数据
- 修复：加IP白名单或认证

5. Cookie安全标志缺失

- 问题：session cookie没有HttpOnly和Secure
- 影响：XSS攻击可以窃取session
- 修复：`cookie: { httpOnly: true, secure: true, sameSite: 'strict' }`

第四步：攻击链还原

AI把漏洞串成完整攻击链：

```
信息收集
  ↓
发现 /api-docs 暴露所有接口
  ↓
分析接口定义，找到登录接口 /rest/user/login
  ↓
测试NoSQL注入，绕过登录获得管理员session
  ↓
用管理员权限访问 /rest/basket/ 查看所有用户订单
  ↓
发现PII数据（邮箱、地址、密码哈希）泄露
```

第五步：对比人工测试

测试项	人工渗透测试	AI平台
信息收集	20分钟	30秒
Nuclei扫描	手动加载模板跑	自动加载13742模板
SQLMap验证	手动判断注入点	自动调SQLMap
报告撰写	2小时	10秒生成
漏报率	-	发现7个，Juice Shop共30+个挑战，覆盖率约23%

诚实说：覆盖率不高。AI平台适合做初筛和自动化，但复杂逻辑漏洞（如JWT伪造、业务逻辑越权）还是需要人工测试。

踩坑记录

1. **Nuclei误报**：/metrics端点在Juice Shop里是故意开放的，不是真漏洞
2. **SQLMap不支持MongoDB**：需要手动写NoSQL payload，平台的AI引擎自动生成了
3. **扫描速度**：13742个模板跑了4分钟，比纯人工快但比云扫描慢

下一步优化

- 增加Juice Shop专属模板，提高覆盖率
- 加JWT分析模块，自动检测弱密钥
- 加业务逻辑测试（水平越权、垂直越权）
- 报告里加截图和复现步骤

项目开源地址

https://github.com/1ouxilisi/ai-security-agent-platform

v45.0 · 12领域59个安全代理 · MIT许可证